SPURVANCE

Internship Program

Submitted By: Maryam Rehan

Mentor: Miss Wania

Topic : Risk Assessment & Vulnerability Management

Part A: Written Quiz

Q1. What is the difference between a threat and a vulnerability?

A threat is something that can cause harm to a system, while a vulnerability is a weakness that a threat can exploit.

Q2. A website has a weak admin password. Name the asset, vulnerability and one threat.

- Asset: Website and its data.
- Vulnerability: Weak admin password.
- Threat: Hacker gaining unauthorized access.

Q3. Likelihood = 4 and Impact = 5. What is the risk score?

Risk Score = Likelihood × Impact

= 4 × 5

= 20 (Critical)

Q4. List the four ways to treat a risk. Give one example of Reduce.

The four risk treatments are Avoid, Reduce, Transfer and Accept. An example of Reduce is enabling Multi-Factor Authentication (MFA) to improve account security.

Q5. What does CVSS measure, and which score range is Critical?

CVSS measures the severity of security vulnerabilities. A score between 9.0 and 10.0 is Critical.

Q6. True or false: A vulnerability scan is the same as an attack. Explain why.

False. A vulnerability scan identifies security weaknesses in a system, whereas an attack attempts to exploit those weaknesses.

Part B: Build a Mini Risk Register

Asset	Threat	Vulnerability	L	I	Score	Treatment
Customer data	Hacker	Weak passwords	4	5	20	Reduce – Add MFA
Website	Cyber attacker	Outdated software	4	5	20	Reduce – Update software
Customer records	Ransomware	No backup	4	5	20	Reduce – Regular backups
Reduce – Regular backups	Unauthorized user	Poor access control	3	5	15	Reduce – Restrict access
Staff accounts	Phisher	Lack of security awareness	3	5	12	Reduce – Security training

Risk score calculate formula:

$$\textbf{Risk Score} = L \times I$$

Score	Risk Level
1–5	Low
6–11	Medium
12–19	High
20–25	Critical

Part C : Find Vulnerabilities

Vulnerability 1: CVE-2026-9860

- CVE ID: CVE-2026-9860
- Product: Offload, AI & Optimize with Cloudflare Images – WordPress Plugin
- Affected Versions: 1.10.2 and earlier
- Published Date: 18 June 2026
- CVSS Score: 8.8
- Severity: High
- Vulnerability Type: Remote Code Execution (RCE)

Description: This vulnerability allows authenticated attackers with Author-level access or higher to execute malicious code on the server. It occurs because of insufficient permission checks and improper validation of the account-id and API key parameters.

OpenCVE+1

Recommended Fix: Update the plugin to a patched version (1.10.3 or later) and ensure proper permission checks and input validation.

NVD Record: CVE-2026-9860

Identifier	CISA Kev Info	Published Date	CNA	Description
CVE-2026-9860	✕	Jun 18, 2026	Wordfence	The Offload, AI & Optimize with Cloudflare Images plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 1.10.2 via the 'account-id' parameter parameter. This is due to insufficient privilege enforcement on the cf_images_do_setup AJAX handler, which require ...

Vulnerability 2: CVE-2026-9855

- CVE ID: CVE-2026-9855
- Product: Custom Field Template – WordPress Plugin
- Affected Versions: 2.7.8 and earlier
- Published Date: 19 September 2026

- CVSS Score: 6.5
- Severity: Medium
- Vulnerability Type: SQL Injection (SQLi)

Description: This vulnerability allows authenticated attackers with Contributor-level access or higher to inject malicious SQL queries through the post_ID parameter. This may allow attackers to extract sensitive information from the website database.

OpenCVE+1

Recommended Fix: Update the plugin to version 2.8 or later. Properly validate user input and use prepared SQL statements to prevent SQL injection.

NextGuard+1

NVD Record: CVE-2026-9855

CVE-2026-9855		Sep 19, 2026	Wordfence	The Custom Field Template plugin for WordPress is vulnerable to generic SQL Injection via the 'post_ID' parameter in all versions up to, and including, 2.7.8 due to insufficient escaping on the user supplied parameter and lack of sufficient preparation on the existing SQL query. This makes it possib ...

Conclusion

Through this assignment, I learned how to identify threats and vulnerabilities, assess security risks, calculate risk scores, and select appropriate risk treatments. I also explored real-world WordPress vulnerabilities using the NVD database and understood the importance of applying security updates and fixes to protect systems and sensitive data.